Lab 50 — Active Reconnaissance with Nmap

> **SY0-701 Objective 5.5** — Explain types and purposes of audits and assessments
>
> **Domain 5** — Security Program Management and Oversight (20%) · **Time:** ~25 min · **Course:** C628 CompTIA Security+ Exam Prep

Goal: Fingerprint a live host with Nmap and understand the trade-off between stealth and speed.

You'll build: An Nmap scan of local nginx and SSH targets — host discovery, SYN scan, version and OS detection, NSE scripts — saved in three report formats.

> **Authorised scope only.** Active scanning sends real traffic and is visible in the target's logs. Scan **only** `127.0.0.1` / the loopback range inside this playground, or hosts explicitly named in a signed rules-of-engagement document. Unauthorised scanning of third-party systems can breach the **Singapore Computer Misuse Act**.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; tools installed in step 1.

Background

- **Active** recon interacts directly with the target by scanning and probing; it confirms what is truly live, not merely what was published.
- A **SYN scan** (`-sS`) is half-open: SYN, read the reply, send RST without completing the handshake.
- **Port states**: open (service listening), closed (RST returned), filtered (no reply — a firewall is dropping the probe).
- **NSE** (Nmap Scripting Engine) scripts in categories like `banner`, `safe` and `vuln` bridge port scanning to vulnerability discovery.
- **Timing templates** `-T0` .. `-T5` trade stealth for speed; `-T3` is default, `-T4` suits an authorised internal test.

Steps

1. Install nmap and start nginx + ssh targets

We run nginx (80) and ssh (22) so the detection steps have real services to fingerprint.

```
apt-get update -qq && apt-get install -y nmap nginx openssh-server
service nginx start || systemctl start nginx
service ssh start || systemctl start ssh
```

2. Discover live hosts with a ping scan

`-sn` confirms a host is alive without scanning any ports.

```
nmap -sn 127.0.0.0/30
```

3. Run a TCP SYN half-open scan

`-sS` is the classic stealth scan; it never completes the handshake.

```
nmap -sS -p 1-1024 127.0.0.1
```

4. Detect service versions

`-sV` probes each open port and names the product and version — the hook for CVE mapping.

```
nmap -sV -p 22,80 127.0.0.1
```

5. Fingerprint the OS

`-O` infers the operating system from TCP/IP stack traits.

```
nmap -O 127.0.0.1 2>&1 | grep -iE "os|device" | head
```

6. Run NSE discovery scripts

These scripts enumerate banners, HTTP headers and SSH crypto — input to TLS/SSH hardening labs.

```
nmap --script=banner,http-headers,ssh2-enum-algos -p 22,80 127.0.0.1
```

7. Review timing templates for stealth vs speed

Measure a full-port scan at an aggressive template (authorised lab only).

```
time nmap -T4 -p- 127.0.0.1 | tail -10
```

8. Save results in three report formats

`-oA` writes `.nmap` (human), `.gnmap` (grep) and `.xml` (machine — what reporting tools consume).

```
nmap -sV -oA scan-127 127.0.0.1
ls scan-127.*
```

Test it

```
nmap -sV -p 22,80 127.0.0.1 | grep -iE "open|nginx|ssh"
ls scan-127.xml
```

Expected: `nmap -sV` reports nginx on port 80 and OpenSSH on port 22 as open, and `scan-127.xml` exists for reporting.

Troubleshooting

Symptom	Fix
nginx/ssh show as filtered or closed	The service did not start; re-run `service nginx start` / `service ssh start`.
`-O` returns "too few ports open"	OS detection needs open and closed ports; add `--osscan-guess` or accept the limitation in a container.
`-p-` scan is very slow	Drop the template to `-T3`, or scan a smaller range for the demo.

Challenge

Run `nmap --script vuln -p 80 127.0.0.1` against the local nginx and explain why a scanner-reported "vuln" still needs a penetration test (Lab 51) to confirm.

Reflection

Objective 5.5 lists passive and active reconnaissance. What did the active scan confirm about the two services that the passive recon in Lab 49 could only have guessed?

Exam tips

- `-sn` = host discovery; `-sS` = SYN stealth; `-sV` = version; `-O` = OS fingerprint. Know all four.
- Port states: open (listening), closed (RST), filtered (firewall dropping the probe).
- Active recon is visible in the target's IDS/SIEM; passive recon is not.
- A scan *reports* a weakness; it does not *prove* exploitability — that is the pentest's job.

References

- Nmap reference guide + NSE — https://nmap.org/book
- MITRE ATT&CK Active Scanning (T1595) — https://attack.mitre.org/techniques/T1595/
- Singapore Computer Misuse Act — https://sso.agc.gov.sg/Act/CMA1993
